

Zimbabwe Commercial Bank ABC: Scope, Goals, and Risk Assessment Report

Scope and Goals of the Audit

Scope

The scope of this audit covers the entire security program of a ABC bank located in Zimbabwe. The audit includes all technology systems, physical assets, employee devices, internal networks, and customer data management processes used by the bank.

The assessment focuses on reviewing:

- Employee equipment and banking devices
- Internal banking networks and communication systems
- Customer databases and financial systems
- Security controls currently in place
- Compliance with banking and data protection regulations
- Disaster recovery and business continuity processes

The purpose of the audit is to identify weaknesses that may expose the bank to cybersecurity threats, financial loss, operational disruption, or regulatory penalties.

Goals

The main goals of this audit are to:

- Assess existing assets and security controls
 - Identify vulnerabilities and risks affecting the bank
 - Evaluate compliance with financial and data protection regulations
 - Determine which security controls and best practices need improvement
 - Strengthen the bank's overall cybersecurity posture
 - Protect customer financial information and confidential records
-

Current Assets

The bank's IT department manages the following assets:

Physical and On-Premises Equipment

- Office computers and laptops
- Banking servers and storage systems
- Smartphones and tablets used by employees
- CCTV surveillance systems
- Printers, routers, keyboards, and networking devices
- Security systems and alarm controls

Employee Equipment

- Remote employee workstations
- Headsets and communication devices
- Docking stations and cables
- Mobile devices used for secure banking communication

Banking Systems and Services

- Customer account management systems
- Financial transaction systems
- Online banking platforms
- ATM management systems
- Accounting and payroll systems
- Database and telecommunications systems
- Security monitoring software

Network and Internet Services

- Internal banking network
- Internet access for banking operations
- Wi-Fi and remote access VPN services

Data Storage and Retention

- Customer financial records
- Employee information
- Loan and transaction records
- Backup systems and archived data

Legacy Systems

- Older banking systems that still require maintenance and monitoring
 - End-of-life software and hardware systems
-

Risk Assessment

Risk Description

The bank currently faces several cybersecurity and operational risks due to weak asset management practices and incomplete security controls. Sensitive customer financial information may be exposed because access controls and encryption are not fully implemented.

Additionally, the bank may not fully comply with local and international financial security standards and privacy regulations.

The lack of strong cybersecurity measures increases the likelihood of:

- Unauthorized access to customer information
 - Financial fraud
 - Data breaches
 - Operational downtime
 - Regulatory penalties
-

Control Best Practices

According to the National Institute of Standards and Technology Cybersecurity Framework (CSF), the first function is **Identify**. The bank must properly identify and manage all assets to reduce cybersecurity risks.

The bank should:

- Create a complete inventory of all hardware and software assets
 - Classify sensitive customer and financial data
 - Assess the impact of asset loss or system failure
 - Implement stronger security controls to protect critical systems
 - Regularly monitor and update security measures
-

Risk Score

Overall Risk Score: 8/10

The bank's current risk level is considered **high** because:

- Important security controls are missing
 - Sensitive customer data is insufficiently protected
 - Compliance practices are incomplete
 - Disaster recovery planning is inadequate
-

Additional Comments and Findings

1. Excessive Access to Sensitive Data

Currently, many employees can access internally stored banking data, including customer personally identifiable information (PII) and financial records.

Risk

Unauthorized access may lead to:

- Data leaks
- Insider threats
- Fraudulent activities

Recommendation

Implement:

- Role-based access control (RBAC)
 - Least privilege access policies
 - Separation of duties
-

2. Lack of Encryption

Customer banking and credit card information stored in internal databases is not fully encrypted.

Risk

Hackers may steal or read sensitive financial information during a cyberattack.

Recommendation

Use:

- Database encryption
 - Secure communication protocols
 - Encrypted backups
-

3. Weak Password Security

Although a password policy exists, it does not meet modern security standards.

Current Weaknesses

- Simple passwords
- Minimal complexity requirements
- No centralized password management system

Risk

Accounts can easily be compromised through brute-force attacks or phishing.

Recommendation

Implement:

- Strong password requirements
 - Multifactor authentication (MFA)
 - Centralized password management
-

4. No Intrusion Detection System (IDS)

The bank does not currently use an intrusion detection system.

Risk

Cyberattacks may go unnoticed for long periods.

Recommendation

Install:

- Intrusion Detection Systems (IDS)
 - Security monitoring and alert systems
-

5. No Disaster Recovery Plan

There is no formal disaster recovery or backup system for critical banking data.

Risk

Natural disasters, system failures, or ransomware attacks could permanently destroy important financial records.

Recommendation

Develop:

- Disaster recovery plans
 - Business continuity plans
 - Regular backup procedures
-

6. Firewall and Antivirus Protection

The bank has:

- Firewalls configured with security rules
- Antivirus software installed and monitored regularly

Benefit

These controls help:

- Block malicious traffic
 - Prevent malware infections
 - Protect internal systems
-

7. Legacy System Risks

Older banking systems are maintained, but there is no clear maintenance schedule.

Risk

Outdated systems may contain security vulnerabilities.

Recommendation

- Create regular maintenance schedules
- Upgrade unsupported systems

- Document emergency response procedures
-

8. Physical Security Measures

The bank's physical facilities include:

- Secure locks
- CCTV surveillance systems
- Fire detection and prevention systems

Benefit

These measures help protect:

- Cash reserves
 - Banking equipment
 - Employee and customer safety
-

Conclusion

The audit shows that the Zimbabwe commercial bank ABC has several important security measures already in place, such as firewalls, antivirus software, and physical security systems. However, major weaknesses still exist in areas such as encryption, access controls, password management, intrusion detection, and disaster recovery planning.

To improve its cybersecurity posture and comply with financial regulations, the bank should prioritize:

- Stronger access controls
- Multifactor authentication
- Data encryption
- Intrusion detection systems
- Disaster recovery planning
- Regular security audits and employee training

Implementing these controls will help protect customer information, reduce cyber risks, and improve the bank's overall operational security.